@apostrophecms/seo Vulnerable to Stored XSS via Unsanitized Google Analytics / GTM ID Injected into Script Tag

Report Type: Weekly · Generated: August 01, 2026 10:30 UTC · Coverage: Jul 31 - Aug 01, 2026

1	0	1	0
Total Advisories	Critical	High	Medium

HIGH	8.7	TLP:CLEAR	PRO
Severity	CVSS / Risk Score	TLP Classification	Customer Tier

Executive Summary

<img width="1919" height="1046" alt="curl" src="https://github.com/user-attachments/assets/8aa19ff1-7f4b-44ee-83d5-d0dd1a0269f6" /> <img width="1919" height="775" alt="xss" src="https://github.com/user-attachments/assets/a65012e8-9b2f-416f-94df-c00493f2ca1d" /> ### Summary The `@apostrophecms/seo` package injects the Google Analytics Tracking ID (`seoGoogleTrackingId`) and Google Tag Manager ID (`seoGoogleTagManager`) directly into `<script>` tag bodies using JavaScript template literals without any sanitization or validation. Any user with editor-level access (the default role for content managers) can set these fields to a malicious value, resulting in stored XSS that executes on every page for every visitor of the site. ### Details The vulnerable code is in `node_modules/@apostrophecms/seo/lib/nodes.js`. **Google Analytics (lines 218–224):** ```javascript // seoGoogleTrackingId is inserted RAW into a <script> body — no escaping, no validation body: [{ raw: ` window.dataL

CONFIDENTIALITY NOTICE: This report is classified PRO tier and intended exclusively for the named recipient. Redistribution, resale, or disclosure to unauthorized parties is strictly prohibited. © 2026 CYBERDUDEBIVASH SENTINEL APEX. All rights reserved.

CYBERDUDEBIVASH® SENTINEL APEX // CONFIDENTIAL - FOR AUTHORIZED USE ONLY

Top Threat Advisories

High-priority advisories ranked by CVSS score, exploitability, and actor attribution.

Advisory Title	Severity	CVSS	EPSS	AI Summary
@apostrophecms/seo Vulnerable to Stored XSS via Unsanitized Google Ana	HIGH	8.7	21.0%	<img width="1919" height="1046" alt="curl" src="https://github.com

MITRE ATT&CK® v15 Mapping

Technique density score: **0.0** · Techniques observed: **0** · Tactics covered: **0**

MITRE ATT&CK techniques pending analyst enrichment. Deploy detection rules from Section 6 to identify related activity.

Threat Actor Intelligence

Attribution analysis across advisories in this report period.

Threat Actor	Count	Associated CVEs / Indicators
CDB-UNATTR-CVE	1	-

Indicators of Compromise (IOCs)

IOC extraction for this advisory is pending enrichment pipeline completion. PRO subscribers receive real-time IOC push to SIEM/SOAR via the SENTINEL APEX webhook at: **GET /api/v1/intel/iocs?advisory={id}**. Full IOC packages include IPv4, domain, SHA256, and URL indicators with confidence scores, first-seen timestamps, and STIX 2.1 formatted bundles.

CYBERDUDEBIVASH® SENTINEL APEX // CONFIDENTIAL - FOR AUTHORIZED USE ONLY

Detection Engineering

Deploy these production-ready detection rules into your SIEM platform to identify exploitation attempts in real time. Compatible with Microsoft Sentinel, Splunk ES, and any Sigma-compatible platform.

Sigma Rule - Webserver / Process Monitoring

```
title: SENTINEL APEX - CDB-ADVISORY Exploitation Attempt
id: cdb-cdb-advisory-det
status: experimental
description: Detects exploitation indicators related to CDB-ADVISORY.
references:
- https://intel.cyberdudebivash.com
author: CyberDudeBivash SENTINEL APEX
date: 2026/08/01
tags:
- attack.initial_access
- attack.t1190
logsource:
category: webserver
detection:
keywords:
- 'CDB-ADVISORY'
condition: keywords
falsepositives:
- Security testing / penetration testing
level: medium
```

Microsoft Sentinel - KQL Query

```
// SENTINEL APEX - @apostrophecms/seo Vulnerable to Stored XSS via Unsanitized Google Analytics / GTM ID Injected into Script Tag
// Advisory | Microsoft Sentinel KQL
let time_window = ago(24h);
SecurityAlert
| where TimeGenerated > time_window
| where Description has "@apostrophecms/seo Vulnerable to Stored "
or AlertName has "@apostrophecms/seo Vulnerable to Stored "
or ExtendedProperties has "@apostrophecms/seo Vulnerable to Stored "
| extend Rule = "APEX-ADVISORY", Severity = "HIGH"
| project TimeGenerated, AlertName, AlertSeverity, Entities, Description, Rule, Severity
| order by TimeGenerated desc
```

Incident Response Playbook

Phase 1 - 0-24 Hours (Containment)

1. Activate IR team; assign lead analyst and executive sponsor.
2. Isolate or WAF-shield @apostrophecms/seo Vulnerable to Stored XSS via Unsanitized Google Analytics / GTM ID Injected into Script Tag instances exposed to the internet.

CYBERDUDEBIVASH® SENTINEL APEX // CONFIDENTIAL - FOR AUTHORIZED USE ONLY

3. Enable verbose access logging on all @apostrophecms/seo Vulnerable to Stored XSS via Unsanitized Google Analytics / GTM ID Injected into Script Tag endpoints immediately.
4. Pull last 72h of web server and application logs for forensic baselining.
5. Check SENTINEL APEX IOC feeds and SIEM alerts for exploitation hits in your environment.
6. Notify relevant internal stakeholders and legal / compliance team.

Phase 2 - 24-72 Hours (Eradication)

1. Apply vendor patch for @apostrophecms/seo Vulnerable to Stored XSS via Unsanitized Google Analytics / GTM ID Injected into Script Tag or implement recommended mitigation.
2. Deploy Sigma and KQL detection rules from Section 6 across all SIEM platforms.
3. Rotate all API keys, service account credentials, and session tokens.
4. Conduct forensic timeline reconstruction for potential compromise window.
5. Validate patch deployment across 100% of affected instances via asset inventory.

Phase 3 - 7 Days (Recovery & Hardening)

1. Conduct post-incident review and update incident response runbooks.
2. Threat hunt for lateral movement or persistence artifacts using MITRE ATT&CK mapping.
3. Update asset inventory with patched version information and closure evidence.
4. Submit findings to internal risk register and CISO dashboard.
5. Schedule follow-up vulnerability scan to confirm remediation completeness.

Financial Impact Analysis (FAIR Model)

$800K - $4.5M	$1.8M	$450K/day	$320K
Breach Cost Range (FAIR)	IBM Cost of Breach 2025 Median	Business Interruption Cost	Regulatory Fine Exposure

High severity incidents activate IR retainers, forensic investigation (avg 47 days), and reputational damage impacting 12-18% of revenue.

Remediation Cost Estimate: $180K · Includes engineering time, IR retainer activation, forensic investigation, and customer notification costs.

Regulatory & Compliance Implications

Organizations processing this advisory must evaluate obligations under applicable regulatory frameworks. The table below maps this threat to relevant compliance requirements.

Framework	Reference	Obligation
GDPR	Art. 32 / Art. 33	Appropriate technical measures; notify DPA if personal data affected

CYBERDUDEBIVASH® SENTINEL APEX // CONFIDENTIAL - FOR AUTHORIZED USE ONLY

Framework	Reference	Obligation
PCI-DSS v4.0	Req. 6.3.3	Patches within 1 month; documented risk acceptance if deferred
NIS2 Directive	Art. 21	Risk management measures including vulnerability handling policies
NIST CSF 2.0	RS.MI / RC.RP	Incident mitigation and recovery planning; post-incident review

Actionable Recommendations

Prioritized defensive actions based on this period's intelligence.

1. Apply patches immediately for @apostrophecms/seo Vulnerable to Stored XSS via Unsanitized Google Analytics / GTM ID Injected into Script Tag.
2. Enable enhanced monitoring for related IOCs.
3. Review SIEM rules for associated MITRE ATT&CK techniques.
4. Apply vendor patch for @apostrophecms/seo Vulnerable to Stored XSS via Unsanitized Google Analytics / GTM ID Injected into Script Tag immediately - check NVD for official fix guidance.
5. Enable enhanced logging and alerting on all systems running affected software versions.
6. Deploy the Sigma detection rule from this report into your SIEM platform (Sentinel / Splunk / Elastic).
7. Audit all internet-facing instances of affected products and confirm patch deployment.

CYBERDUDEBIVASH® SENTINEL APEX // CONFIDENTIAL - FOR AUTHORIZED USE ONLY

Appendix - Report Metadata & Legal

Field	Value
Report ID	intel--4f88ac91b8ad49409a2f2e93
Report Type	Weekly
Platform	CYBERDUDEBIVASH SENTINEL APEX v166.0 GOD-MODE
Generated At	2026-08-01T10:30:35.76402
Customer Tier	PRO
Customer Email	-
TLP	TLP:CLEAR
STIX Version	2.1
ATT&CK Version	v15

Legal & Usage Notice

This threat intelligence report is produced by CYBERDUDEBIVASH SENTINEL APEX, operated by Bivash Nath (GSTIN: 21ARKPN8270G1ZP). All intelligence is aggregated from public vulnerability databases (NVD, CVSS), threat feeds, and proprietary AI enrichment pipelines. This report is provided AS-IS for informational and defensive security purposes only. CYBERDUDEBIVASH accepts no liability for actions taken based on this intelligence. Redistribution, resale, or disclosure to unauthorized parties is strictly prohibited without written consent. For licensing inquiries: enterprise@cyberdudebivash.com

CYBERDUDEBIVASH® SENTINEL APEX // CONFIDENTIAL - FOR AUTHORIZED USE ONLY